UNITÀ 1 · LEZIONE 5 · NETWORK E WEB APP SECURITY

Tre falle nel negozio

Juice Shop ha più di cento sfide. Risolvine tre nuove e, come un professionista, spiega la causa e proponi la correzione.

Cosa consegni: un file **juice-shop-cognome.pdf** (2-4 pagine, con schermate) su Novaula, nella scheda Compiti. **Scadenza:** quella indicata su Novaula.

Prima di iniziare. Avvia Juice Shop **sul tuo computer** come in laboratorio (Docker) o con il pacchetto Node.js indicato su GitHub; se a casa non puoi, usa le ore di laboratorio indicate dal docente. Attacca solo **http://localhost:3000**.

Che cosa devi fare

1. Dallo Score Board scegli **3 sfide da 1 o 2 stelle** diverse da Score Board e Login Admin, possibilmente di categorie diverse. Ottime per cominciare: *Error Handling*, *Confidential Document*, *DOM XSS*, *Zero Stars*, *Admin Section*, *View Basket*.
2. Per ogni sfida scrivi: nome e stelle, categoria OWASP Top 10 2021 (A01…A10), i passi che hai fatto, una schermata con il banner "You successfully solved a challenge".
3. Spiega la **causa** in 2-3 righe: che cosa ha sbagliato lo sviluppatore?
4. Proponi la **correzione**: un frammento di codice (Java, JavaScript o pseudocodice) o una configurazione, e spiega perché funziona.

Esempio di scheda

Sfida	Login Admin (2 stelle) · A03 Injection
Causa	L'e-mail viene concatenata nella query SQL, quindi `' OR 1=1--` cambia la condizione e annulla il controllo della password.
Correzione	`PreparedStatement` con segnaposto `?` per e-mail e hash della password; messaggi d'errore generici.

> *"L'unico sistema davvero sicuro è spento, chiuso in un blocco di cemento…"* · **Gene Spafford**, *frase a lui attribuita (1989). Un negozio deve restare acceso: le falle si correggono una per una.*

Come viene valutato

Criterio	Punti
Tre sfide risolte e documentate con schermata	3
Categoria OWASP corretta per ciascuna	2
Causa spiegata con precisione	2
Correzione corretta e motivata	2
Cura del documento	1

Juice Shop è volutamente vulnerabile e si usa solo in locale. Provare le stesse tecniche su un sito reale, anche "solo per vedere", è un reato (art. 615-ter c.p.).